

CYBERSECURITY CASE STUDY

Vulnerability Prioritization, Incident Response and CSF 2.0

CISA KEV • EPSS • NIST SP 800-61r3 • NIST CSF 2.0

Alshaima Syed

Vulnerability Management | Incident Response | GRC

Executive summary

This case study integrates vulnerability management, ransomware incident response and NIST CSF 2.0 governance for a representative critical-infrastructure organization. Vulnerabilities were prioritized using asset presence, reachability, CISA KEV and EPSS rather than CVSS alone. A ransomware tabletop applied the NIST incident-response lifecycle, and quantitative risk analysis supported a 12-month governance roadmap.

Outcome

The assessment produced risk-based remediation tiers, a defensible ransomware response strategy, annualized-loss estimates totaling \$595,000 per year across two major scenarios, and a roadmap designed to improve governance and recovery maturity.

Core resources	CISA KEV, FIRST EPSS, NVD, NIST SP 800-61r3 and NIST CSF 2.0.
Security focus	Prioritization, incident command, evidence preservation, recovery and governance.
Decision method	Business context + exposure + exploitation evidence + technical severity.
Financial lens	\$375,000 and \$220,000 annualized-loss estimates for two modeled scenarios.
Scope	Scenario-based analysis using public guidance and provided synthetic organizational data.

Risk-led operating model

Prioritize	Confirm asset, reachability and exploitation likelihood before assigning SLA.
Respond	Detect, contain, eradicate, recover and capture lessons with evidence integrity.
Govern	Assign ownership, fund controls, measure maturity and track delivery.
Improve	Use incidents, risk metrics and testing results to update the roadmap.

Vulnerability prioritization

The filter prevented severity-only decision making. A vulnerability could be technically severe but out of scope when the affected product was not present. Conversely, a reachable vulnerability with confirmed exploitation or strong EPSS evidence received urgent treatment.

P1 — 7 days	Confirmed/reachable exposure with KEV or strong exploitation likelihood.
P2 — planned urgent	Material exposure requiring prompt remediation but lower immediate evidence.
Out of scope	Affected product not confirmed in the environment; retain evidence and revalidate inventory.

Illustrative decisions

CVE-2024-3400	P1 — confirmed internet-facing VPN exposure and exploitation relevance.
CVE-2023-36884	P1 — user interaction path with KEV evidence.
CVE-2021-44228	P1 pending asset confirmation — validate vendor application composition.
CVE-2023-44487	P2 — reachable web exposure without the same exploitation signal.
Absent products	Out of scope, but only after documented asset confirmation.

Log4Shell validation workflow

- Contact the application vendor for component and version confirmation.
- Request an SBOM and patch/advisory evidence.
- Inspect local packages and runtime evidence where authorized.
- Apply compensating controls while uncertainty remains.
- Document ownership, decision date, evidence and revalidation trigger.

Ransomware incident-response tabletop

Scenario

The exercise considered ransomware involving credential compromise and pass-the-hash behavior. The response emphasized rapid containment without destroying volatile evidence or creating uncontrolled operational impact.

Detect & analyze	Validate scope, impacted identities, lateral movement, affected services and business impact.
Contain	Isolate compromised systems, disable exposed accounts/tokens and restrict lateral paths.
Eradicate	Remove persistence, reset credentials, patch exploited weaknesses and validate clean images.
Recover	Restore in priority order, test integrity, increase monitoring and obtain business approval.
Post-incident	Complete root-cause analysis, control mapping, lessons learned and tracked corrective actions.

Key decisions

- Preserve memory, logs, identity telemetry, disk evidence and chain of custody before destructive action when feasible.
- Coordinate containment with operational owners to avoid unsafe service interruption.
- Do not treat ransom payment as recovery assurance; prioritize tested backups and legal/executive decision channels.
- Use a defined incident commander, communications plan and regulatory assessment process.

Response quality

A strong tabletop is judged by decision clarity, evidence preservation, authority and recovery validation—not by how quickly every system is disconnected.

Quantitative risk and governance

Annualized loss expectancy

Scenario A	$\text{ARO } 0.15 \times \text{SLE } \$2,500,000 = \$375,000/\text{year}.$
Scenario B	$\text{ARO } 0.20 \times \text{SLE } \$1,100,000 = \$220,000/\text{year}.$
Combined modeled exposure	\$595,000/year before considering wider regulatory and reputational effects.

CSF 2.0 maturity assessment

Governance was identified as the root dependency because unclear roles, policy ownership and risk accountability weaken every other function. The roadmap therefore begins with accountability, inventory and risk processes before expecting mature detection and recovery outcomes.

GOVERN	Clarify roles, risk appetite, policies, vendor oversight and executive reporting.
IDENTIFY	Establish authoritative asset, identity, software and risk inventories.
PROTECT	Strengthen segmentation, vulnerability management, IAM and backup safeguards.
DETECT	Centralize telemetry and validate prioritized use cases.
RESPOND	Approve plans, roles, communications and exercise cadence.
RECOVER	Test restoration, service priorities and lessons-learned closure.

12-month roadmap

Months 1–3	Assign governance owners; validate critical asset inventory; approve vulnerability SLAs and incident authority.
Months 4–6	Implement high-priority remediation, segmentation, identity controls and centralized logging.
Months 7–9	Exercise ransomware response; test backups; close evidence, communications and vendor gaps.
Months 10–12	Measure maturity, validate control effectiveness and refresh risk/ALE assumptions.

Skills demonstrated

Vulnerability management	Asset-aware KEV/EPSS/CVSS prioritization and remediation SLAs.
Incident response	Containment trade-offs, evidence preservation, recovery validation and PIR.
GRC	CSF 2.0 maturity assessment, ownership and roadmap design.
Risk quantification	SLE, ARO and ALE calculations supporting investment decisions.
Executive communication	Connected technical exposure to operational and financial impact.

Conclusion

The project demonstrates how vulnerability, incident and governance decisions reinforce one another. Exploitation-aware prioritization focuses limited resources, practiced response reduces uncertainty during crisis, and governance ensures that ownership, funding and measurement persist after the immediate issue is closed.

Selected references

NIST CSF 2.0 — <https://www.nist.gov/cyberframework>
NIST SP 800-61 Rev. 3 — <https://csrc.nist.gov/pubs/sp/800/61/r3/final>
CISA KEV Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
FIRST EPSS — <https://www.first.org/epss/>
NIST NVD — <https://nvd.nist.gov/>